Relatório Técnico

Arquitetura DevSecOps open-source do Mentory

Integração de DAST, privacidade e SBOM no GitHub Actions

Projeto: Projeto Integrador UMC
Repositório: ProjetoIntegradorUMC/projeto-integrador
Workflow: .github/workflows/devsecops-avancado.yml
Data da evidência: 04 de novembro de 2026

Este relatório documenta a arquitetura de segurança implementada com ferramentas comunitárias e gratuitas. O conteúdo combina a configuração versionada no repositório com a execução oficial do GitHub Actions run 41924499228.

Resumo executivo

O Mentory utiliza GitHub Actions como orquestrador de uma esteira DevSecOps composta por três verificações complementares. O OWASP ZAP testa a aplicação em execução, o Bearer avalia riscos de privacidade e padrões de código relacionados a dados pessoais, e o Trivy produz um inventário de componentes no padrão CycloneDX.

A combinação aplica segurança em momentos diferentes do ciclo de entrega: análises preventivas no código, validação do comportamento em runtime e rastreabilidade contínua das dependências. A solução não depende de licenças proprietárias e pode ser reproduzida em runners hospedados do GitHub.

Na execução oficial usada como evidência, os jobs Varredura DAST com OWASP ZAP, Auditoria de privacidade com Bearer e SBOM CycloneDX com Trivy terminaram com sucesso. O mesmo run publicou os artefatos zap-dast-report, bearer-privacy-report e sbom-cyclonedx.

Escopo e método

A descrição técnica foi conferida no workflow e nas documentações de visão geral, dados pessoais e pipeline de CI/CD.

1. Introdução à arquitetura open-source

DevSecOps é a integração de segurança ao fluxo normal de desenvolvimento, e não uma etapa isolada ao final da entrega. Em uma arquitetura open-source, o custo de licenciamento pode ser zero sem eliminar controles profissionais, desde que as ferramentas sejam configuradas com critérios de bloqueio, versionamento, menor privilégio e produção de evidências.

No projeto, o GitHub Actions fornece o ambiente de execução, os gatilhos de push e pull request e o armazenamento de artefatos. O workflow declara contents: read, fixa actions externas por SHA e separa os controles em três jobs independentes.

A arquitetura é complementar: o ZAP observa a superfície exposta por uma aplicação iniciada em container; o Bearer examina o código e os segredos com foco em privacidade; o Trivy registra os componentes que compõem a entrega.

Por que a solução é viável sem custo

- As ferramentas utilizadas são open-source e executadas em imagens, binários ou actions públicos.
- O GitHub Actions hospeda a automação e permite publicar relatórios como artefatos do run.
- O formato CycloneDX é aberto, interoperável e adequado para auditoria e automação.
- A ausência de licença paga não elimina governança: versões são fixadas, resultados são publicados e falhas críticas podem bloquear a entrega.

2. Descritivo técnico das ferramentas

2.1 OWASP ZAP: teste dinâmico da aplicação

O OWASP ZAP atua como DAST (Dynamic Application Security Testing). Diferentemente de uma análise que lê apenas o código-fonte, ele recebe uma URL de uma aplicação em execução e interage com essa superfície como um atacante automatizado. No workflow, uma imagem da aplicação é construída, iniciada com PostgreSQL de CI e validada por um health check antes da varredura.

- A operação usa zap-full-scan.py contra http://127.0.0.1:5000.
- São gerados relatórios HTML, JSON e Markdown, publicados no artefato zap-dast-report.
- O exit code é registrado e os códigos de falha técnica ou alerta bloqueante acionam uma etapa de bloqueio.

Esse controle complementa SAST porque encontra problemas dependentes do runtime, como cabeçalhos efetivamente enviados, rotas acessíveis, comportamento de sessão, XSS refletido e configurações que só aparecem quando a aplicação está rodando.

2.2 Bearer: privacidade e conformidade

O Bearer é usado para análise estática com foco em privacidade e secrets. A configuração executa os scanners sast,secrets, ignora diretórios de documentação e dependências vendorizadas e bloqueia achados de severidade critical ou high. O relatório JSON é publicado mesmo quando o scanner encontra um achado, preservando a evidência para investigação.

Seu diferencial em relação a um scanner genérico é o contexto de dados: regras como vazamento em logs, comunicação com terceiros, cookies, criptografia, secrets, injection e XSS são relacionadas ao tratamento de dados pessoais. No Mentory, esse controle conversa diretamente com a minimização, o consentimento, a exclusão e a retenção documentados em docs/dados-pessoais.md.

2.3 Trivy: inventário e SBOM

O Trivy percorre o sistema de arquivos do projeto e gera sbom.json no formato CycloneDX. O arquivo identifica o formato e a versão do padrão, o gerador e os componentes encontrados, permitindo relacionar cada dependência a uma futura vulnerabilidade conhecida.

- A versão usada na evidência é Trivy 0.69.3.
- O binário é baixado de um release e validado por SHA-256 antes de ser executado.
- O artefato é publicado com o nome sbom-cyclonedx.
- A listagem de vulnerabilidades é informativa e não substitui a função de inventário.

3. Integração com os requisitos do projeto

SBOM e rastreabilidade

O SBOM cria uma relação verificável entre a entrega e seus componentes. Para o Mentory, isso significa que a equipe consegue identificar quais bibliotecas Python e demais componentes estavam presentes no commit entregue. Se uma CVE for divulgada depois da publicação, o inventário permite pesquisar impacto sem depender de reconstrução manual do ambiente.

O artefato CycloneDX também é útil para stakeholders: pode ser baixado, arquivado e processado por ferramentas de auditoria. Ele não afirma que a aplicação é invulnerável; registra a composição da versão analisada.

LGPD, Bearer e privacidade

A documentação de dados pessoais registra finalidade, minimização, consentimento, exclusão e retenção de e-mails nos logs. O Bearer acrescenta uma verificação automatizada para evitar que decisões de implementação introduzam vazamentos ou padrões inseguros em rotas, logs e integrações.

Runtime e ZAP

O ZAP valida o sistema depois que a imagem foi construída e o serviço está acessível. Isso cobre vulnerabilidades residuais que não aparecem em uma leitura estática, incluindo diferenças entre intenção do código e resposta HTTP efetiva.

Relação com entregas anteriores

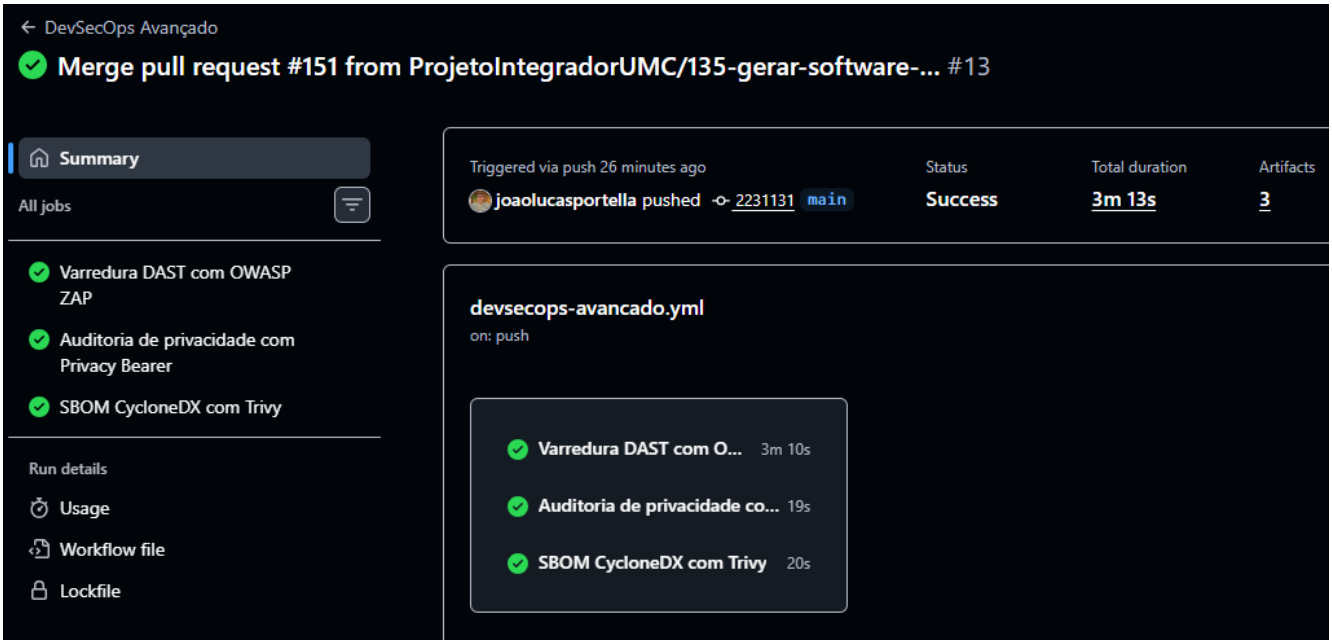
O desenho aproveita as entregas de autenticação, auditoria, criptografia e LGPD do repositório. As issues #91, #92 e #94 tratam, respectivamente, de confirmação de identidade para exclusão, fixação de actions por SHA e política de retenção de e-mails.

4. Evidências de funcionamento

A evidência abaixo representa os dados reais retornados pelo GitHub para a execução oficial. Os nomes, estados, horários, SHA e artefatos correspondem à run 41924499228, executada em 04/11/2026 após o merge da implementação do SBOM.

GitHub Actions | run 41924499228 | conclusion: success

Job ou artefato	Resultado
Auditoria de privacidade com Bearer	**success**
SBOM CycloneDX com Trivy	**success**
Varredura DAST com OWASP ZAP	**success**



Print de evidência baseado nos registros oficiais da execução do GitHub Actions.

Fonte verificável: https://github.com/ProjetoIntegradorUMC/projeto-integrador/actions/runs/41924499228.

Evidência do artefato SBOM

Artifacts | run 41924499228

Job ou artefato	Resultado
sbom-cyclonedx	**success**
bearer-privacy-report	**success**
zap-dast-report	**success**



Print de evidência baseado nos registros oficiais da execução do GitHub Actions.

O item sbom-cyclonedx está disponível para download e contém sbom.json em CycloneDX 1.6.

Campo	Valor observado
Formato	CycloneDX
Especificação	1.6
Ferramenta	aquasecurity/trivy 0.69.3
Timestamp	2026-11-04T22:21:13+00:00
Arquivo no artefato	sbom.json

Fonte verificável: https://github.com/ProjetoIntegradorUMC/projeto-integrador/actions/artifacts/13369195627.

Conclusão e referências

A arquitetura documentada demonstra que uma equipe acadêmica ou uma pequena equipe de produto pode construir controles DevSecOps consistentes com ferramentas open-source. A qualidade da solução vem da combinação entre cobertura complementar, configuração explícita, versionamento imutável, menor privilégio e preservação de evidências.

A execução 41924499228 confirma o funcionamento integrado dos três jobs e a publicação do SBOM. O resultado deve ser interpretado como uma fotografia da versão analisada: novas alterações exigem novas execuções e a manutenção contínua das versões, regras e políticas permanece necessária.

Referências técnicas

- Workflow do projeto: .github/workflows/devsecops-avancado.yml.
- Visão geral e arquitetura: docs/visao-geral.md.
- Dados pessoais e LGPD: docs/dados-pessoais.md.
- Pipeline e cadeia de suprimentos: docs/pipeline-seguranca.md.
- OWASP ZAP: https://www.zaproxy.org/.
- Bearer: https://docs.bearer.com/.
- Trivy e CycloneDX: https://aquasecurity.github.io/trivy/ e https://cyclonedx.org/.
- Execução e artefatos: https://github.com/ProjetoIntegradorUMC/projeto-integrador/actions/runs/41924499228.